

Tabletop Exercise: Insider Theft of High-Net-Worth Client Data

Introduction

This tabletop exercise is designed to test the organization's ability to detect, assess, contain, investigate, and manage an insider-driven theft of sensitive private-banking client information. The scenario is based on the uploaded STIX bundle describing a departing employee with legitimate access who exports an unusually large volume of client-book data and uses an unapproved external storage device. The exercise focuses on insider-risk detection, legal and HR coordination, evidence handling, executive decision-making, client-impact assessment, and regulatory response planning.

Exercise Overview

Scenario title: Insider Theft of High-Net-Worth Client Data

Exercise type: Discussion-based tabletop exercise

Primary audience: Executive leadership, Security Operations, Incident Response, Legal, HR, Compliance, Privacy, Client Relationship Management, Communications, and Technology leadership

Suggested duration: 60–90 minutes

Scenario basis: STIX report "TTX Scenario 5 - Insider theft of high-net-worth client data"

Scope

The exercise covers:

- Detection of suspicious customer-data exports by a departing employee
- Triage and confirmation of potential insider activity
- Containment of user access, workstation, storage media, and relevant systems
- Coordination across Security, Legal, HR, Privacy, Compliance, and business leadership
- Decisions on offboarding suspension, legal hold, forensics, and disciplinary action
- Customer-notification, regulator-notification, and law-enforcement considerations
- Executive and client communications
- Recovery, lessons learned, and control improvements

The exercise does not require participants to perform technical remediation live. It is intended to validate roles, escalation paths, decision-making, and inter-team coordination.

Objectives

By the end of the exercise, participants should be able to: 1. Recognize indicators of insider misuse involving legitimate access to sensitive client data. 2. Assess the severity and business impact of potential theft of high-net-worth customer records. 3. Coordinate security, legal, HR, privacy, and business actions during an active offboarding-related case. 4. Make defensible decisions on access revocation, device preservation, legal hold, and evidence handling. 5. Evaluate regulatory, contractual, confidentiality, and client-notification obligations. 6. Demonstrate effective executive escalation and communications management. 7. Identify control gaps related to monitoring, offboarding, privileged access, removable media, and customer-data handling.

Assumptions

- The suspected employee is a relationship manager or equivalent role with legitimate access to private-banking client records.
- The employee is in the final week of employment and maintains normal business access at exercise start.
- The organization has centralized logging for customer-record exports and endpoint telemetry for USB/removable-media activity.
- Legal, HR, Privacy, and Compliance functions are available for urgent consultation.
- Not every fact is known at the start; information will emerge through injects.

Rules of Engagement

- This is a no-fault learning exercise.
- Discuss actions based on current policies, authorities, and realistic resource constraints.
- Use your real role where possible.
- Treat scenario details as credible unless an inject changes them.
- Real-world incidents take priority over the exercise.

Participant Roles

Executive / Crisis Leadership

- Chief Information Security Officer or delegate
- Chief Operating Officer / business executive
- Head of Private Banking / business line lead
- Crisis manager

Operational / Control Functions

- Security Operations Center
- Incident Response / Digital Forensics

- Insider Risk / Fraud / Monitoring team
- Legal counsel
- HR / Employee Relations
- Privacy office / Data protection lead
- Compliance / Regulatory affairs
- Communications / Media relations

Technical / Business Support

- Identity and Access Management
- Endpoint engineering
- Data governance / DLP team
- Private-banking operations
- Client relationship management leadership

Scenario Summary

Monitoring identifies an unusually large export of high-net-worth client records performed by a departing employee during their final week of employment. Initial review suggests the activity may be outside normal business need. Additional evidence indicates possible copying of data to an unapproved external storage device. The organization must determine whether this is a policy violation, data theft, attempted client-book poaching, or a broader compromise involving other actors or systems.

The incident rapidly becomes a cross-functional matter involving confidentiality, employee-rights considerations, client trust, evidentiary preservation, regulatory obligations, and potential civil or criminal action.

Exercise Timeline and Injects

Inject 1 — Initial Detection

Exercise time: 09:00

Inject:

Monitoring alerts show that a relationship manager exported an unusually large volume of high-net-worth client records during the final week before resignation. The volume is materially above the employee's baseline behavior and includes records outside the employee's usual portfolio.

What participants know at this stage:

- A named employee is in the offboarding period.
- A large export of customer data has occurred using legitimate credentials.
- The export appears to involve private-banking client data.

- Intent and destination are not yet confirmed.

Discussion questions:

- How is the incident classified initially?
- What immediate investigative steps should be taken before alerting the employee?
- Who must be notified in the first hour?
- What evidence must be preserved immediately?
- At what point should the incident be escalated to executive visibility?

Expected actions:

- Open a priority insider-risk/security incident.
- Preserve application, database, DLP, endpoint, email, and authentication logs.
- Validate export scope, timing, data classes, and account activity.
- Review offboarding status, manager approvals, and business justification.
- Engage Legal and HR before any employee confrontation.
- Identify whether privileged access or access beyond job scope was used.

Facilitator notes: Look for disciplined handling of evidence and avoidance of premature confrontation. Strong responses should balance speed with legal defensibility.

Inject 2 — Removable Media Indication

Exercise time: 10:00

Inject:

Endpoint telemetry indicates an unapproved external storage device was connected to the employee's workstation within the same time window as the export activity. File-copy activity is suspected, but investigators cannot yet confirm the exact files transferred.

What participants know at this stage:

- There is a likely connection between the export event and removable media use.
- The employee still has access to corporate systems and may still be on site or remote.
- There is a risk of destruction of evidence or onward disclosure.

Discussion questions:

- Do you immediately revoke access, or do you continue covert monitoring for a period?
- Should departure processing be suspended?
- How should HR and Legal coordinate an interview or device seizure?

- What chain-of-custody steps are required for the laptop and any storage media?
- What business continuity concerns arise if the employee manages active client relationships?

Expected actions:

- Decide on containment strategy: immediate disablement versus controlled monitoring.
- Preserve workstation, USB, and endpoint forensic evidence.
- Place the employee account, mailbox, and collaboration data under legal hold as appropriate.
- Coordinate HR, Legal, Security, and management for any interview or exit intervention.
- Review physical access records, printing, email forwarding, cloud uploads, and messaging activity.
- Identify clients potentially affected and sensitivity of the records involved.

Facilitator notes: Participants should discuss the tradeoff between preserving intelligence value and preventing additional loss. Good responses will also address dignity, confidentiality, and employee-rights considerations.

Inject 3 — Intent Becomes Clear

Exercise time: 11:30

Inject:

A preliminary review of messages and case notes indicates the employee has accepted a role with a competitor and may have intended to use the copied client-book data after departure. There is no evidence yet that the data has been publicly posted or sold.

What participants know at this stage:

- Motive may involve client solicitation and competitive misuse.
- The primary risk may be confidentiality breach, client poaching, and regulatory exposure rather than immediate public leak.
- The case is now highly sensitive from legal, reputational, and client-trust perspectives.

Discussion questions:

- Does this trigger notification analysis now, or only after confirmed external disclosure?
- What legal actions should be considered immediately?
- Which clients or relationship segments should be prioritized for impact analysis?

- How should executives be briefed?
- Should the organization contact the new employer or law enforcement at this stage?

Expected actions:

- Conduct a formal breach and notification assessment.
- Segment affected clients by sensitivity, residency, and contractual/regulatory obligations.
- Prepare executive talking points and a privileged legal briefing.
- Consider cease-and-desist, preservation demand, or civil action options.
- Assess whether regulator pre-notification is advisable.
- Increase monitoring for suspicious client outreach, anomalous logins, and external mentions.

Facilitator notes: This stage should force discussion beyond pure IT containment. Strong groups will distinguish between confirmed facts, legal theories, and assumptions.

Inject 4 — Decision Point: Contain, Notify, Escalate

Exercise time: 13:00

Inject:

The bank must decide whether to suspend departure processing, preserve devices, notify affected clients, and coordinate law-enforcement or civil action. Investigators estimate that several hundred high-net-worth client records may have been exposed, including contact details, account relationship details, and portfolio-related information.

Discussion questions:

- Who has authority to make final decisions on client notification and regulator outreach?
- What threshold determines whether clients are contacted now versus later?
- How should relationship managers be instructed if clients notice unusual contact or mention the departing employee?
- What external statements, if any, are approved?
- How will the organization prevent inconsistent messaging across Security, HR, Legal, and business leaders?

Expected actions:

- Convene a cross-functional decision cell.
- Approve a client-risk decision framework and notification criteria.

- Determine whether to suspend offboarding completion and retain equipment.
- Finalize legal hold, forensic acquisition, and case-management steps.
- Prepare regulator-ready chronology, facts known, and actions taken.
- Establish communication controls for employees, leadership, and client-facing teams.

Facilitator notes: Watch for governance clarity. Participants should identify who decides, who advises, and who executes.

Inject 5 — Resolution and Aftermath

Exercise time: 15:00

Inject:

The employee's access has been revoked, devices preserved, and the immediate threat contained. The organization now needs to determine final notifications, pursue legal remedies, monitor for downstream misuse, and document lessons learned.

Discussion questions:

- What are the next steps over the next 24 hours, 7 days, and 30 days?
- What post-incident reporting is required?
- What control gaps most likely enabled the incident?
- How should the organization monitor for delayed misuse of the stolen client information?
- What improvements are needed in offboarding and insider-risk governance?

Expected actions:

- Produce an executive after-action summary.
- Complete regulatory and privacy assessments.
- Monitor dark web, client complaints, suspicious outreach, and competitor-contact patterns.
- Review removable-media controls, access governance, alert thresholds, and manager approvals.
- Update offboarding playbooks and insider-risk detection content.
- Capture lessons learned and assign remediation owners.

Decision Points

1. **Classification:** policy violation, insider threat, privacy incident, or material breach?
2. **Containment:** covert monitoring versus immediate account disablement.

3. **Employment action:** continue offboarding, suspend departure, or immediate termination.
4. **Evidence handling:** when and how to seize devices and preserve media.
5. **Client notification:** who, when, and under what threshold.
6. **Regulatory engagement:** immediate notice, preliminary advisory, or post-investigation reporting.
7. **Legal response:** civil action, law-enforcement referral, or both.

Business and Technical Impact Considerations

Business Impacts

- Loss of trust among high-net-worth clients
- Potential client attrition and competitive harm
- Reputational damage in a highly relationship-driven business
- Regulatory scrutiny and possible sanctions
- Litigation and contractual exposure

Technical / Control Impacts

- Weak monitoring of abnormal export behavior
- Inadequate controls on removable media
- Excessive or poorly reviewed user entitlements
- Insufficient offboarding risk controls for sensitive roles
- Potential evidence gaps if endpoint or DLP telemetry is incomplete

Facilitator Prompts by Audience

Executive audience

- What is the organization's risk appetite for early client notification?
- What threshold makes this an enterprise crisis rather than an HR-led matter?
- What would the Board expect to know in the first briefing?

Operational audience

- How are Legal, HR, Privacy, and Security synchronized in the first four hours?
- Which records are privileged, and how is evidence protected?
- How do you document decisions in a way that is defensible later?

Technical audience

- What telemetry confirms data export volume, scope, and destination?
- What controls exist for USB insertion, file copy, mass export, and unusual query volume?

- How do you preserve volatile and persistent evidence without tipping off the subject too early?

Expected Good Practices

- Risk-based escalation using predefined insider-risk criteria
- Immediate preservation of logs and endpoint evidence
- Tight coordination between Security, Legal, and HR before employee engagement
- Clear decision authority for notifications and employment actions
- Privileged briefing materials for executives
- Client-impact analysis driven by data sensitivity and jurisdiction
- Structured lessons learned tied to remediation owners

Debrief / Lessons Learned

Use the final 10–15 minutes to discuss:

- What worked well in detection and cross-functional coordination?
- Where were roles unclear or overlapping?
- Were legal and HR dependencies understood early enough?
- Would current tooling detect and prove USB-based exfiltration?
- Are offboarding controls proportionate for high-risk roles?
- What would you change in the next 30 days?

Suggested Improvement Actions

- Tighten offboarding controls for client-facing and privileged roles.
- Implement or strengthen abnormal export and insider-risk analytics.
- Restrict or block unapproved removable media.
- Require enhanced approval and logging for bulk customer-data exports.
- Review least-privilege and segregation of duties for private-banking roles.
- Pre-build legal/HR/security playbooks for insider cases.
- Exercise client-notification decision frameworks before a real incident.

Mapping to the Source STIX Bundle

The exercise is derived from the uploaded STIX objects describing:

- the participant organization as a financial-services entity;
- a disgruntled insider threat actor with client-book access;
- an unapproved external storage device used as a tool;
- an attack pattern involving exfiltration of customer data using legitimate access;
- an incident involving theft of high-net-worth customer data;

- inject notes covering unusual export activity and decisions on legal hold, client risk, and law-enforcement/civil action;
- courses of action related to abnormal export alerting and cross-functional insider case management.

MITRE ATT&CK Mapping

The STIX bundle directly supports an insider misuse scenario centered on legitimate access, abnormal collection of customer data, and likely copying to removable media. The following ATT&CK mapping is the most defensible fit for this scenario:

Tactic	Technique	Why it fits this scenario
Collection	T1213.004 – Data from Information Repositories: Customer Relationship Management Software	The scenario involves a relationship manager accessing and exporting client-book/customer data from systems used to manage customer relationships and records.
Defense Evasion / Persistence / Privilege Escalation / Initial Access	T1078 – Valid Accounts	The employee abuses legitimate credentials and authorized access rather than malware or unauthorized intrusion.
Exfiltration	T1052.001 – Exfiltration over USB	The uploaded STIX tool is an unapproved external storage device, consistent with copying data to USB/removable media.
Exfiltration	T1052 – Exfiltration Over Physical Medium	Parent technique for physical-media exfiltration when the precise medium is removable external storage.

ATT&CK-informed detections and mitigations to discuss

- Monitor for high-volume or abnormal access to customer records by users who do not typically perform such actions at that scale.
- Detect USB insertion followed by sensitive file access or staging activity.
- Apply DLP and endpoint controls to block or alert on copying sensitive customer information to removable media.
- Enforce least privilege, especially for employees in notice periods or sensitive client-facing roles.

- Perform periodic reviews of accounts and privileges for critical customer-data repositories.

Source References

- Uploaded STIX bundle: [filecite?turn0file0](#)
- ATT&CK reference for exfiltration over USB and related detection guidance.
- ATT&CK reference for abuse of valid accounts.
- ATT&CK reference for customer relationship management data collection.
- ATT&CK reference for data loss prevention mitigations.